

API Reference

Base URL prefix: /api/v1. All responses use a consistent envelope.

Response envelope

Every endpoint — success or error — returns:

```
{
  "success": true,
  "data": { "...": "..." },
  "error": null,
  "request_id": "uuid",
  "timestamp": "2026-08-04T00:00:00Z"
}
```

On error, success is false, error is a human-readable string, and data may carry a state field from the honest-degradation vocabulary (e.g. NOT_CONFIGURED, UNAVAILABLE).

Authentication

Obtain a token with POST /auth/login, then send it as Authorization: Bearer <access_token> on every protected request. Access tokens expire in 15 minutes (configurable, capped at 24 h); use POST /auth/refresh with the refresh token to get a **new pair** — the presented refresh token is revoked (rotation), and revocations persist across restarts. Tokens are HS256 with iss=airone, aud=airone-api.

Login outcomes: 401 generic for unknown user *or* wrong password, 403 with data.state = PASSWORD_CHANGE_REQUIRED (call /auth/change-password), 429 with Retry-After and data.state = ACCOUNT_LOCKED / IP_LOCKED after too many failures.

Request bodies are strictly validated: unknown fields → 400. Bodies above api.max_body_bytes (256 KiB) → 413. Every response carries X-Request-ID, X-Content-Type-Options: nosniff, X-Frame-Options: DENY, a restrictive Content-Security-Policy and Cache-Control: no-store on auth/user/config routes.

Roles

Roles are hierarchical: a higher role satisfies a lower requirement.

VIEWER (0) < OPERATOR (1) < SCIENTIST (2) < ENGINEER (3) < ADMIN (4)

Endpoints

Auth

Method	Path	Role	Notes
POST	/auth/login	public	Returns access + refresh tokens. Rate-limited 10/min.
POST	/auth/refresh	public	Exchanges a refresh token for a new access token. 30/min.
POST	/auth/logout	authenticated	Revokes the presented token (persisted).
POST	/auth/change-password	public (credentials in body)	{username, current_password, new_password} — for must-change accounts.
POST	/auth/password	authenticated	{current_password, new_password} — change own password.

Users (ADMIN)

Method	Path	Role	Notes
GET	/users	ADMIN	List accounts (no hashes).
POST	/users	ADMIN	{username, password, role, must_change_password?} → 201. Password policy enforced.
DELETE	/users/<username>	ADMIN	Delete an account (not your own).
POST	/users/<username>/disable	ADMIN	Disable login and refresh.
POST	/users/<username>/enable	ADMIN	Re-enable.

Status & health

Method	Path	Role	Notes
GET	/status	public	Liveness + honest link_state (NOT_CONFIGURED until a link is opened).
GET	/health	VIEWER	Worker/queue health snapshot.

Telemetry

Method	Path	Role	Notes
GET	/telemetry/latest	VIEWER	Latest measurement per sensor, with quality.
GET	/telemetry/history	VIEWER	Windowed history.
POST	/telemetry/export	OPERATOR	Exports data (incl. quality states). 5/min. Returns file (sanitised basename), never a path.

Mission

Method	Path	Role	Notes
GET	/mission	VIEWER	Mission overview.
GET	/mission/primary	VIEWER	Primary objective status.
GET	/mission/secondary	VIEWER	Secondary objective status.
POST	/mission/state	ENGINEER	Request a mission-state transition (validated by the state machine).

Analysis (Tier 2 — science)

Method	Path	Role	Notes
GET	/analysis	VIEWER	Lists all 37 analyses and

Method	Path	Role	Notes
GET	/analysis/results	VIEWER	their specs. Latest live results from the scientific worker.
GET	/analysis/<name>	VIEWER	One analysis spec + latest live result.
POST	/analysis/<name>/run	SCIENTIST	Run one analysis over stored telemetry.
GET	/narrative	VIEWER	Natural-language mission narrative.
GET	/fusion	VIEWER	Latest fused measurements.

ML / AI (Tier 3 — advisory only)

Method	Path	Role	Notes
GET	/ml/detectors	SCIENTIST	Live availability probe for each detector.
GET	/ml/models	SCIENTIST	Model registry list.
GET	/ml/models/<id>	SCIENTIST	One model's provenance (404 if unknown).
GET	/ml/anomalies	SCIENTIST	Live advisory anomaly summary. 503 NOT_CONFIGURED if the ML worker is not running.
GET	/ml/drift	SCIENTIST	Population-stability drift metrics.
POST	/ml/train	SCIENTIST	Trains a detector on stored telemetry. 2/hour. See below.

POST /ml/train body: {"model_type": "ensemble", "name": "...", "parameters": {"limit": 5000, "features": [...]}}. Responses: - 400 — unknown model_type (lists

valid types). - 422 — well-formed but cannot honestly proceed (no stored data, or fewer than the minimum training samples). The response explains exactly why; **no fake model is created**. - 200 — trained; returns model_id, version, n_samples, training_data_hash, and the artefact sha256_hash.

Everything in the ML tier is advisory. No ML endpoint can change mission state. See [ml_tier.md](#).

Configuration

Method	Path	Role	Notes
GET	/config	ENGINEER	Current effective configuration.
PUT	/config	ENGINEER	{"config": {...}} — only runtime-mutable keys; api/security/storage/telemetry → 400. Secrets redacted in GET. 20/min.
POST	/config/validate	ENGINEER	Validate a config without applying it.

System

Method	Path	Role	Notes
GET	/events	VIEWER	Recent system/audit events.
GET	/system/logs	ENGINEER	Structured logs.
GET	/system/metrics	OPERATOR	Runtime metrics.

Status codes

Code	Meaning in AirOne
200	Success.
400	Malformed request / validation error.
401	Missing/invalid/expired token.
403	Authenticated but insufficient role, or PASSWORD_CHANGE_REQUIRED.
404	Unknown resource (model, analysis).
422	Well-formed request that cannot honestly be fulfilled (e.g. train with no data).

Code	Meaning in AirOne
413	Request body too large.
429	Rate limit exceeded, or account/IP locked (Retry-After).
503	A required tier/worker is NOT_CONFIGURED / not running.